CyberLens: Threat-Informed Vulnerability Prioritization

Data Visualization (103001004) — Practical Project Proposal (Dataset Approval)

Student: Evan Gendrot (Erasmus — INSA Rennes) | **Supervisor:** Prof. Pablo Toharia Rabasco | **Date:** October 2026

1. APPLICATION DOMAIN & PROBLEM CHARACTERIZATION (MUNZNER LEVEL 1)

Enterprise Security Operations Centers (SOC) and Vulnerability Management teams face acute alert fatigue, with over **28,000 Common Vulnerabilities and Exposures (CVEs)** cataloged each year. Regulatory compliance frameworks traditionally mandate immediate patching for all vulnerabilities with a "High" or "Critical" Common Vulnerability Scoring System base score (CVSS ≥ 7.0).

However, threat intelligence research shows that **less than 4.5% of published CVEs are ever weaponized in real-world attacks**. Simultaneously, several vulnerabilities rated as "Medium" (4.0 ≤ CVSS ≤ 6.9) due to local access prerequisites are actively leveraged in targeted intrusion chains for privilege escalation and lateral movement.

> **Why Visual Analytics is essential (vs Database Queries):** Security teams cannot resolve this triage dilemma through static queries like `SELECT * WHERE cvss >= 7.0`. Risk trade-offs are non-linear, multi-dimensional, and organizational risk tolerance varies continuously. A visual interface is required to explore trade-off frontiers, discover hidden threat discrepancies, and filter vulnerabilities to the organization's specific active technology stack.

Target Persona: Enterprise Vulnerability Manager & Cyber Threat Intelligence (CTI) Lead managing a heterogeneous corporate stack (Linux, Windows Server, Cisco devices, web servers, databases).

2. DATASET SELECTION & DATA ABSTRACTION (MUNZNER LEVEL 2: WHAT)

The dataset merges three authoritative, standardized public cybersecurity feeds:

- **NIST NVD (National Vulnerability Database):** Official CVSS v3.1 metrics (base score, impact score, attack vector, complexity, privileges required) and MITRE CWE classifications.
- **FIRST.org EPSS v3 (Exploit Prediction Scoring System):** Daily statistical probability (0.0 to 1.0) of active in-the-wild exploitation within 30 days.
- **CISA KEV (Known Exploited Vulnerabilities):** Authoritative catalog of confirmed weaponized vulnerabilities observed in real attacks, including disclosure and weaponization dates.

Attribute	Structural Role	Munzner Type	Direction	Semantic Description	Domain / Values
`cve_id`	Item ID (Key)	Categorical	—	Unique standardized CVE identifier	String (e.g. `CVE-2024-38063`)
`vendor`	Independent Key	Categorical	—	Software publisher or device vendor	Microsoft, Linux, Cisco, Apache, etc.
`layer`	Structural Key	Categorical	—	Enterprise architectural tier	OS & Firmware, Network, Web/App, Database
`cwe_family`	Classification Key	Categorical	—	MITRE Weakness taxonomy family	Memory Corruption, Injection, Auth Bypass, etc.
`cvss_base`	Dependent Value	Ordered → Quantitative	Sequential	Theoretical technical severity score	Continuous: 0.0 to 10.0
`cvss_impact`	Dependent Value	Ordered → Quantitative	Sequential	Destructive technical impact score	Continuous: 0.0 to 6.0
`epss_score`	Dependent Value	Ordered → Quantitative	Sequential	Empirical 30-day exploit likelihood	Continuous: 0.000 to 1.000 (Heavy-tailed)
`is_kev`	Dependent Value	Categorical	—	Observed weaponization in the wild	Boolean: `True` / `False`
`attack_vector`	Dependent Value	Ordered → Ordinal	Sequential	Access boundary required for exploit	Network > Adjacent > Local > Physical
`privileges_req`	Dependent Value	Ordered → Ordinal	Sequential	Authentication level required	None < Low < High
`days_to_exploit`	Derived Metric	Ordered → Quantitative	Sequential	Elapsed duration: disclosure to KEV date	Continuous non-negative duration (days)

3. ANALYTICAL TASKS & TASK ABSTRACTION (MUNZNER LEVEL 2: WHY)

The analytical tasks are structured across the three levels of action abstraction (high-level goal, search, and query) and formulated to avoid simplistic SQL queries (such as min/max day lookups):

Task 1: Bivariate Risk Profiling & Discrepancy Discovery

- **Analytical Question:** *"Where are the divergence zones between theoretical severity (CVSS) and empirical exploit probability (EPSS), and which medium-CVSS vulnerabilities represent critical imminent threats that standard compliance filters miss?"*
- **High-Level Action (Use):** `Consume → Discover` (Generate and verify risk hypotheses).
- **Mid/Low-Level Action & Target:** `{Explore, Identify, Outliers & Correlation}` on quantitative CVSS, quantitative EPSS, and categorical KEV status.
- **Visual Need:** Threshold boundaries are flexible; the analyst visually explores the continuous space to balance risk tolerance against available patch resources.

Task 2: Structural Attack Primitives & Weakness Taxonomy Breakdown

- **Analytical Question:** *"How do vulnerabilities partition across technology layers, and which weakness families (CWE) concentrate the highest aggregate risk across network vs local attack vectors?"*
- **High-Level Action (Use):** `Consume → Discover` (Explore structural dependencies).
- **Mid/Low-Level Action & Target:** `{Browse, Compare, Summarize, Hierarchical Distribution}` on layer, CWE family, attack vector, and aggregated risk weight.
- **Visual Need:** Replaces flat tabular listings with an enclosed hierarchical structure, making systemic architectural weaknesses immediately visible.

Task 3: Continuous Weaponization Velocity & Hazard Distribution

- **Analytical Question:** *"How does the continuous probability density of time-to-exploit differ across vendor cohorts (e.g. immediate zero-day spikes within 7 days vs prolonged decay over months)?"*
- **High-Level Action (Use):** `Consume → Discover` (Analyze longitudinal trends).
- **Mid/Low-Level Action & Target:** `{Locate, Compare, Continuous Density / Distribution}` on vendor cohort and continuous elapsed days.
- **Visual Need:** Avoids simplistic min/max lookups by modeling the continuous Kernel Density Estimation (KDE) curve for each vendor cohort.

4. VISUAL ENCODING & INTERACTION IDIOMS (MUNZNER LEVEL 3: HOW)

Idiom 1: Prioritization Multi-Channel Bubble Plot

- **Course Reference:** *Tables Slide 9 (Bubbleplots) & Vis-04 (Marks and Channels)*.
- **Encodings:** Spatial position X encodes `cvss_base`; spatial position Y encodes `epss_score` (spatial position dominates the mental model per Stevens' Law). Mark size encodes destructive impact (`cvss_impact`, area-scaled). Mark color hue encodes weaponization status (Red = active CISA KEV, Amber = high EPSS ≥ 0.30, Gray = low priority).
- **Interaction:** Operational quadrant crosshair sliders, box/lasso selection, contextual hover tooltips.

Idiom 2: Architectural Weakness Hierarchical Treemap

- **Course Reference:** *Tables Slide 64 (Space-filling & Treemap layouts)*.
- **Encodings:** Spatial containment marks hierarchy: Level 1 (Layer) → Level 2 (CWE Family) → Level 3 (Vendor). Cell area encodes aggregate risk (CVSS × EPSS). Color luminance encodes the proportion of network-exploitable flaws.
- **Interaction:** Click-to-zoom hierarchical drill-down, bidirectional cross-filtering with Idiom 1.

Idiom 3: Multi-Cohort Exploitation Velocity Ridgeline Density Plot

- **Course Reference:** *Tables Slide 32 (Ridgeline Plot for multiple time series in limited space)*.
- **Encodings:** Continuous X-axis encodes elapsed days (0 to 120). Separated vertical baselines encode vendor cohorts (list alignment). Curve height encodes continuous probability density (KDE). Color fill distinguishes cohorts.
- **Interaction:** Cohort toggles and threshold highlights.

Coordinated Interaction & Algorithmic Integration

- **Global Enterprise Asset Filter:** Multi-select component allowing the analyst to filter the dataset to their company's specific software stack (e.g., Linux, Windows, Cisco, Apache), dynamically updating all three views.
- **Machine Learning Bonus:** Unsupervised K-Means clustering in 4D space (`[CVSS, EPSS, Impact, Complexity]`) discovering 4 threat archetypes (*Critical Weapons, Silent Threats, Paper Tigers, Backlog*).

5. IMPLEMENTATION PLAN & MILESTONES

- **October 5, 2026 (Milestone 1):** Formal approval of dataset and task abstraction specification.
- **October – November:** Data pipeline, statistical exploratory data analysis (EDA), and iterative visual encoding design in Shiny.
- **December – January 11, 2027:** Multi-view coordination, formal report drafting (Munzner 4 levels), and cloud deployment.